SIGPN-T — Security audit: consolidated specification

Status: **the seven lots are implemented** (approved on 2026-11-09 and delivered lot by lot, sections 6 to 13). The audit itself was read-only; the changes were made only after the specification was approved.

Date: 2026-11-09. Sources read: `prisma/schema.prisma`, `src/server/rbac/*`, `src/server/auth/*`, `src/server/hr/transfers.ts`, `src/server/org/service.ts`, the immutability triggers, and the environment settings.

1. Decisions approved by the client
2. Comparison table
3. Implementation lots (proposed order) p. 2
4. Open points (not decided, not invented) p. 3
5. What this specification does not change
6. Approval requested p. 3
7. Lot 1 — status (implemented 2026-11-09) p. 3
8. Lot 2 — status (implemented 2026-11-09) p. 4
9. Lot 6 — status (implemented 2026-11-09) p. 4
10. Lot 3 — status (implemented 2026-11-09) p. 5
11. Lot 4 — status (implemented 2026-11-09) p. 5
12. Lot 5 — status (implemented 2026-11-09) p. 6
13. Lot 7 — status (implemented 2026-11-09) p. 6
14. Summary of the seven lots p. 7

1. Decisions approved by the client

#	Decision	Status
1	The official organisation chart of the Chadian National Police is authoritative: DGPN, 23 provinces, about 300 commissariats, personnel. Administrators create and reorganise units. **No count is hardcoded.** The full chart will be supplied later.	Approved
2	Access follows the chain of command (supervision). Administrative geography is kept for filtering and statistics. A commissaire manages only their commissariat; a provincial director supervises the commissariats under their authority.	Approved
3	Technical administrators lose all operational powers: no approval of warrants, wanted notices or custody decisions, no access to confidential investigations.	Approved
4	MFA is mandatory for leadership, technical and security administrators, users with sensitive clearance, users who approve sensitive operations, and roles classed high-risk. Optional for ordinary users.	Approved
5	Clearances: three provisional tiers (standard, sensitive, confidential) until the Direction supplies the official levels.	Approved, provisional
6	Double approval only for sensitive roles and special permissions. Ordinary account creation needs one authorised approval.	Approved
7	Sensitive permissions: warrant approval, wanted notices, custody extension, role and permission changes, creation of technical or security administrators, viewing sensitive or confidential files, HR discipline and pay, export and deletion of data.	Approved
8	Single approval: the commissaire for station accounts, the provincial director for provincial accounts. Sensitive accounts: two approvers from different levels of the chain.	Approved
9	Separate the technical administrator (platform, no police data) from the security administrator (audit logs and accounts). Neither holds operational powers.	Approved
10	On reassignment: scope switches to the new unit at execution; sensitive permissions are suspended until a supervisor re-approves; sessions are revoked; open cases and tasks stay with the old unit until a supervisor reassigns them.	Approved
11	Audit log is never deleted and is hash-chained; the security administrator can verify the chain. The retention period is a legal question for the Direction.	Approved; period open
12	Reads of sensitive and confidential cases and documents, wanted persons and warrants are logged.	Approved
13	Sensitive accounts: shorter idle timeout (proposed 15 min) and one active session. API keys: mandatory expiry, rotation every 90 days, no sensitive permissions, visible and revocable by the security administrator.	Approved

2. Comparison table

Requirement	Existing	Proposed	Gap	Risk	Recommended action
RBAC	About 155 `module:action` permissions, 28 system roles, enforced server-side on pages, actions and API	Keep as is	None	Low	Keep
ABAC / org scoping	Scope levels NATIONAL, REGIONAL, DEPARTMENTAL, STATION, OWN based on the user's posting. `OWN` behaves like `STATION`	Scope derived from the chain of command, geography kept for filters; real `OWN`	No "reports to" relation; `OWN` not distinct	High: a director sees units by geography, not authority	Lot 2
Hierarchical access	Region, department, station tree	Official levels (DGPN, province, commissariat, subordinate unit), editable by admins, no hardcoded counts	Level names differ; chain not modelled	Medium	Lot 2, after the official chart is supplied
Individual accounts	One account per person, password min 12, 90-day max age, history 5, lock after 5 failures	Keep	None found	Low	Keep
Module / action permissions	Present and tested (35 security tests)	Keep	None	Low	Keep
Special clearances	Only `isSensitive` on cases, `cases:view_sensitive`, `documents:view_confidential`	Three provisional tiers attached to users and to records	No clearance concept on users	High	Lot 3
Approval workflows	Four-eyes for warrants and search-warrant notices. None for account creation, role grants or permission changes	One generic mechanism, single or double approval by sensitivity	No generic mechanism	High	Lot 4
Admin / command separation	`SUPER_ADMIN` holds every permission except `hr:pay_*`	Technical admin and security admin, neither operational	Administrator can approve warrants and view everything	**Critical**	Lot 1
Secure audit log	Append-only by database trigger; no hash chain; reads logged only for HR dossiers, discipline, pay and public submissions	Hash chain, verification by the security admin, reads of sensitive records logged	No tamper evidence; incomplete read coverage	High	Lot 6
Revocation after reassignment	Transfer updates the user's station, region and department only; role and sessions unchanged	Sessions revoked, sensitive permissions suspended until re-approved	Old privileges survive a transfer	High	Lot 5
MFA	TOTP; 18 of 28 roles require it, set by role	Required by permission or clearance, optional otherwise	Rule is per role, not per sensitivity	Medium	Lot 3
Session management	Idle 60 min, absolute 10 h	Sensitive accounts: idle 15 min, one session	No stricter profile	Medium	Lot 7
API keys	Exist and are tested	Expiry, 90-day rotation, no sensitive permissions, admin visibility	Expiry and permission limits to be checked in detail	Medium	Lot 7
Departure / dismissal	Dismissal or departure disables the account	Keep	None	Low	Keep

3. Implementation lots (proposed order)

Every lot uses additive migrations only, keeps existing functionality, adds tests, and is committed separately. Each lot is shown to you before the next begins.

Lot	Content	Depends on	Main risk	Rollback

TECHNOTCHAD

1. Separate administration	Create `TECH_ADMIN` and `SECURITY_ADMIN`; remove operational permissions from administrative roles; keep one documented emergency procedure so the system cannot be locked out	none	Locking everyone out of operational approvals during the change	Restore previous role-permission rows from the migration's saved copy
2. Organisation and chain of command	"Reports to" relation between units; editable unit levels and labels; scope computed from the chain; real `OWN` scope	Official chart (for final names only)	Wrong visibility if the chain is incomplete	Scope falls back to the current geographic rule
3. Sensitivity and clearance	Catalogue of sensitive permissions; three clearance tiers on users and records; MFA required by permission or clearance	Lot 1	Users blocked until they enrol MFA	Feature flag to switch the rule back to per-role
4. Approval workflow	Generic request/approve mechanism; single approval for ordinary accounts, double for sensitive ones; applied to account creation, role changes and sensitive grants	Lots 1, 2, 3	Slows administration	Workflow disabled per action type
5. Reassignment effects	Scope switch, suspension of sensitive permissions, session revocation, supervisor re-approval	Lots 2, 4	Officers temporarily lose rights during a transfer	Suspension lifted manually by a supervisor
6. Audit hardening	Hash chain, verification page for the security admin, read logging of sensitive records	Lot 1	Slight write overhead	Chain verification is additive; logging can be turned off
7. Sessions and API keys	Sensitive-account timeout and single session; key expiry, rotation, permission limits	Lot 3	Shorter sessions annoy users	Settings are configuration values

4. Open points (not decided, not invented)

1. The full official organisation chart, including names of levels and units.
2. The official clearance levels and their names.
3. The audit retention period and archive rules.
4. Which exact roles the Direction classes as "high-risk".
5. The 15-minute idle timeout for sensitive accounts is a proposal, not a policy.
6. Whether the 48-hour custody limit and the sensitive-permission list match the law and the Direction's policy.

5. What this specification does not change

Existing data, accounts, APIs and screens stay as they are until a lot is approved. No police rank, structure or authorisation policy has been invented here: where the client has not supplied one, it appears above as an open point.

6. Approval requested

Please state which lots you approve, and in which order. Lots 1 and 6 can start without the official chart. Lot 2 can start with the current structure and be adjusted when the chart arrives.

7. Lot 1 — status (implemented 2026-11-09)

Done. Administration is separated from police command.

Item	Result
Technical administrator (`SUPER_ADMIN`, name changed)	11 platform permissions: settings, backups, demonstration data, organisation structure, role catalogue. No police permission, no audit log, no account management.
Security administrator (`SECURITY_ADMIN`, new)	15 permissions: accounts, sessions, security centre, audit log. No police permission.
Both roles	National, MFA required, locked against edition from the interface.
Existing databases	One-time step on start-up removes the operational permissions from `SUPER_ADMIN` (marked in `SystemSetting`, audited). Applied to the development database.
First accounts	`BOOTSTRAP_ADMIN_*` creates the technical administrator, `BOOTSTRAP_SECURITY_*` the security administrator (each only when none exists). Demonstration account `security.admin` added.
Tests	135 unit, 200 integration (6 new on the real server), 35 security, `tsc` clean. About 15 integration files moved from the old all-powerful `admin` account to the operational account that really holds the permission.

Choices made, to confirm.
1. The code `SUPER_ADMIN` is kept (and renamed "Technical Administrator") instead of creating `TECH_ADMIN`, so existing accounts, the last-administrator guards and the bootstrap keep working.

TECHNOTCHAD

2. Interim rule until lot 4: the security administrator may grant any role except the two administrator roles without holding its permissions (granting is not holding). Without this rule nobody could create an investigator or desk account, since no other role holds all their permissions. Lot 4 puts approval on this.
3. The technical administrator keeps `roles:manage`. It can only grant permissions it holds, so it cannot make a role operational. Lot 4 puts double approval on role changes.
4. `POLICE_ADMIN` is not touched: it is a police role and still holds command permissions (warrants, wanted notices, custody extension). Whether it should is a question for the Direction.
5. Creating a second technical or security administrator is possible only through the bootstrap variables for now.

Not proven. The change has not been browsed in the interface (the administrator accounts need MFA enrolment, which was not done on the development data), and French and Arabic role labels were not looked at on screen.

8. Lot 2 — status (implemented 2026-11-09)

Source. Decree N° 0572/PT/PM/MSPI/2023 of 11 April 2023 on the organisation of the Ministry of Public Security and Immigration (supplied by the client). It sets the DGPN (a Director General with two deputies), its central directions (articles 24 to 42), the provincial police delegations led by a "délégué provincial de Police" (articles 87 and 94), and says the detailed organisation is fixed by a ministerial arrêté (article 91). That arrêté has **not** been supplied, so the commissariat level is not modelled beyond what already exists.

Item	Result
Provincial title	"Délégué provincial de Police" (French) and "المندوب الولائي للشرطة" (Arabic) replace "Directeur provincial". The unit type "Délégation" is labelled "Délégation provinciale de Police" and can now be created from the organisation screen.
Central directions	New unit type `CENTRAL_DIRECTION` (additive migration). The 10 directions and 4 units of the decree (DSP, DLGDEAM, DPTSCI, DIE, DRHM, DITT, DLS, DSPSM, DBCN-IP, DENP, GMIP, GSR, USIP, UNILT) are created under the DGPN headquarters at start-up, idempotent, never renamed or moved afterwards. Applied to the development database.
Alerts	Central directions have no duty desk and receive no alert of the national network. They are also excluded from the complaint and operations unit pickers.
Departmental level	Not in the decree. It stays available as a geographic level; the departmental commander role is described as "awaiting confirmation by the Direction, not to be assigned".
Chain of command	The existing tree already follows it: DGPN, province (délégation), commissariat, attached post or unit (`Station.parentId`). No new relation was added.
Tests	`tsc` clean, 138 unit, 203 integration (9 new across lots 1 and 2), 35 security.

Not done in this lot.
1. The real `OWN` scope is not built: no system role uses it today, and building it means an ownership rule in every module. It is left until a role needs it.
2. The sub-directions and services of each direction, and the commissariats, wait for the ministerial arrêté.
3. Mapping the functional heads (HR, forensic, Interpol, IT) to their roles is not done; it needs the Direction's confirmation.
4. Not browsed in the interface; Arabic names of the central units are not stored (French names only).

9. Lot 6 — status (implemented 2026-11-09)

Done. The audit log is tamper-evident and the reading of sensitive records is logged.

Item	Result
Hash chain	Every audit row carries its position (`chainSeq`), the hash of the previous row (`prevHash`) and its own SHA-256 hash over the previous hash and its content. The database sets them on every insert, whatever the code path (application, seed, raw SQL). An advisory lock serialises writers so two rows can never take the same position. Additive migration; the append-only triggers are unchanged.
Existing history	The 24,034 rows that already existed were chained in time order by the migration (the append-only trigger lifted for that block only, then enabled again).
Verification	`pms_audit_verify()` walks the whole chain and returns the first break with its reason (row altered, row removed, link rewritten, row without position) and the head (position and hash). Exposed as `GET /api/v1/audit/verify` and as a button on the security page, for holders of `audit:view` (the security administrator and the auditor; not the technical administrator). Every verification is itself audited, and a broken chain is logged as a failure.
Reads logged	Consulting a **sensitive case** (`CASE_VIEWED`) and **any warrant** (`WARRANT_VIEWED`) is audited with the reader's identity, on the page and through the API. Wanted notices, HR dossiers, disciplinary files, pay and public submissions were already logged. An ordinary case read is not.
Tests	`tsc` clean, 138 unit, 209 integration (6 new on the real server and database), 35 security. The new tests alter, remove and re-link a row inside transactions that are always rolled back, and check that each is located; 60 concurrent writers keep the chain intact.

Limits, stated plainly.
1. The history before the migration is chained from that day on: it proves nothing about changes made before.
2. Removing the **newest** rows cannot be seen from inside the database. The security administrator must record the head (position

and hash) outside the database from time to time; the page prints it for that purpose.
3. Someone with full control of the database server can disable the triggers and rewrite the whole chain consistently. The chain defeats an application-level or partial tampering and makes any other change detectable only against an external record of the head.
4. Documents are not built yet, so reading confidential documents is not logged; it must be added with that module.
5. The verification walks the whole log (about two seconds for 25,000 rows); it runs on request only. The audit writes are serialised by the lock, a small cost per write.
6. Not browsed in the interface (the security administrator needs MFA enrolment).

10. Lot 3 — status (implemented 2026-11-09)

Done. Sensitive permissions, clearance tiers and multi-factor authentication by sensitivity.

Item	Result
Sensitive permissions	One catalogue (19 permissions) built from decision 7: warrant approval, wanted-notice approval and publication, custody extension, role management, sensitive and confidential records, HR discipline and pay, exports of data (reports, audit, wanted, traffic) and backups. In `src/server/rbac/sensitivity.ts`.
Clearance	New field on the user (`STANDARD`, `SENSITIVE`, `CONFIDENTIAL`, provisional tiers). A sensitive permission is **usable only by a user cleared for it** (documents: confidential tier). It is enforced once, where the actor is built, so every page, action and API route follows without change. Withdrawing a clearance withdraws the permissions at once.
No regression	The migration backfilled every existing user from the permissions their role already holds (8 sensitive, 11 confidential, 18 standard on the development database), so nobody lost access on the day.
Who grants it	Only the security administrator, never for their own account; each change revokes the user's sessions, notifies them and is audited (`USER_CLEARANCE_CHANGED`). A field in the user form, visible to the security administrator only.
MFA	Mandatory when the role says so, **or** the role holds a sensitive permission, **or** the user is cleared above standard. Optional for ordinary accounts, as decided. Only the Crime Analyst role is newly affected among system roles. The security overview counts the pending enrolments with this rule.
First accounts	Accounts created by the bootstrap and the demonstration seed receive the clearance their role implies.
Tests	`tsc` clean, 143 unit, 214 integration (5 new on the real server), 35 security.

Effects to know.
1. An account created by anyone other than the security administrator starts at `STANDARD`: its sensitive permissions exist in the role but cannot be used until the security administrator clears it. This is the intended control, and a visible change for commanders who create deputies.
2. The Crime Analyst role (and any custom role holding a sensitive permission) now requires MFA: existing analyst accounts must enrol at their next sign-in.

Limits.
1. Record tiers reuse the flags that already exist (a case or evidence item flagged sensitive, a restricted document); no new classification column was added. A member of a sensitive case's team still sees it without clearance, as before.
2. Clearance changes are made by one person, without approval, until lot 4 adds the approval workflow.
3. The role and user lists still show the role's own MFA flag; the rule is enforced and counted correctly, but those two badges do not yet show the sensitive-permission cause.
4. API keys are not subject to MFA (unchanged).
5. Not browsed in the interface; the French and Arabic texts of the new field were not looked at on screen.

11. Lot 4 — status (implemented 2026-11-09)

Done. Account, role and clearance changes now go through an approval workflow.

Item	Result
What needs approval	**Creating an account** (every account), **changing a user's role**, **raising a clearance**, and **adding a sensitive permission to a role**. Lowering a clearance and removing permissions stay immediate (they only reduce access).
How many approvers	**One** for an ordinary account. **Two** when the role is sensitive (holds a sensitive permission, or is an administrator role), when a clearance is involved, or when a sensitive permission is added to a role.
Who approves	A commander holding the new `approvals:decide` permission whose scope **covers the account's placement**: the commissaire for a station account, the délégué provincial for a provincial one, or a commander above. Never the requester, never the person concerned, never twice.
Two approvers	They must come from **two different levels of the chain** (for example a commissaire, then a departmental or provincial commander): two commissaires do not count. For an account with no placement (national) and for role permissions, two distinct approvers with national authority.
Execution	After the last approval the change is replayed **as its requester**, through the same service function a direct change used (all its checks run again). If it cannot be executed (for example the username was taken meanwhile) the request ends as `FAILED` with the reason; nothing is half-applied.

Secrets	The temporary password is checked at request time and stored **hashed**; no plaintext sits in a request and no listing or API response carries the payload.
Database guards	A vote cannot be altered or deleted (append-only) and the requester cannot vote on their own request, even by raw SQL.
Trace	Every step is audited and hash-chained: requested, approved, rejected, cancelled, expired, executed, failed.
Interface	New **Approbations** page (to decide, my requests, and everything for the security administrator), `GET /api/v1/approvals` and `POST /api/v1/approvals/{id}` (approve, reject with a mandatory comment, cancel). Creating a user now sends a request. French and Arabic texts.
Tests	`tsc` clean, 151 unit (including a guard that fails if any code writes an account or role change around the workflow), 223 integration (9 new), 35 security.

Choices made, to confirm with the Direction.

1. Every account creation needs one approval, including one made by a commissaire (who then needs a commander above, or another commander of the station).
2. The two administrator roles need two approvers with **national** authority, who are police commanders. Whether police command should approve technical and security administrators is a question for the Direction.
3. A request expires after **7 days**.
4. "Different levels" is read as different scope levels (station, department, province, national).
5. Approvers are notified in general terms (no personal data), all holders of the permission at once.

Limits.

1. After the last approval the change is executed just after the vote is recorded, not in the same transaction: if the server stopped exactly between the two, the request would stay `APPROVED` and need a manual retry (no automatic retry exists yet).
2. The account creation screen now ends on the Approbations page, and the new account appears only after approval; the roles screen can only reach this workflow for custom roles (the two administrator roles stay locked).
3. Not browsed in the interface (the approvers need MFA enrolment); French and Arabic texts not looked at on screen.
4. The bootstrap accounts and the demonstration seed are written directly, by design (nobody exists yet to approve).

12. Lot 5 — status (implemented 2026-11-09)

Done. A reassignment no longer carries sensitive access along (decision 10).

Effect	Result
Scope	Switches to the new unit when the transfer is executed (already the case; now tested).
Sessions	All the person's sessions end at the moment of the move (reason `reassigned`).
Sensitive permissions	Suspended: the clearance goes back to **standard**, so every sensitive permission becomes unusable at once (audited as `USER_CLEARANCE_SUSPENDED`).
Re-approval	A request `USER_CLEARANCE_RESTORE` is created automatically for the **supervisors of the new unit** (a commander whose scope covers it); **one approval** gives the previous clearance back, and the person's sessions end again so the new rights apply. The commander of the old unit has no authority over it, and the person cannot approve their own.
Open cases and tasks	They **stay with the old unit** and nothing is reassigned silently. The supervisors of the old unit (holders of `cases:assign`) are notified how many open cases and tasks of the person need a new owner.
Same rule everywhere	The effects apply to the three ways a person changes unit: a transfer validated by hand, a transfer executed by the automatic rotation, and an administrator moving the account to another station. A change that is not a change of unit (a name, a role) leaves clearance and sessions alone.
Tests	`tsc` clean, 152 unit, 227 integration (4 new on the real server, including a real transfer through the whole circuit), 35 security.

Choices made, to confirm.

1. The re-approval needs **one** approval, not two: the clearance was already granted through the full workflow, and the new unit's supervisor is the person best placed to decide. Say so if the Direction wants two.
2. The re-approval request expires after the 7 days of every request; after that the clearance stays at standard until the security administrator raises it again through the normal workflow.
3. Only a change of **station** counts as a reassignment. A change of service inside the same station does not suspend anything.

Limits.

1. The count of open work is given in a notification; there is no dedicated "to reassign" list screen yet.
2. The person keeps being recorded as lead of their old cases until a supervisor reassigns them; they can no longer see them through their new scope, which is the intended effect.
3. A person who commands a station or heads a service cannot be transferred at all (existing rule): the effects above therefore concern everyone else.
4. Not browsed in the interface.

13. Lot 7 — status (implemented 2026-11-09)

Done. Sessions of sensitive accounts are tighter, and API keys are capped, restricted and supervised.

Item	Result
Sensitive account	An account whose role holds a sensitive permission, or whose clearance is above standard.
Idle timeout	**15 minutes** for a sensitive account (60 for an ordinary one; `SESSION_SENSITIVE_IDLE_MINUTES`). The flag is stored on the session when it is created.
One session	A sensitive account has **one active session**: signing in again ends the previous one (reason `single_session`, audited as `SESSION_REPLACED`). An ordinary account may keep several.
Key validity	A key created by the application **always expires**, between 1 and 90 days (`API_KEY_MAX_DAYS`). No key outlives 90 days from its creation, whatever its own expiry says (rotation). Existing keys without expiry were given one at creation + 90 days.
Key permissions	A key created by the application **never carries a sensitive permission**: it cannot approve, decide, export or read sensitive records, whoever owns it. A commander's key still reads. Keys already existing were brought under the same rule.
Oversight	The security administrator sees **every active key** of every user (prefix only, never the secret) on the security page and through `GET /api/v1/security/api-keys`, and can revoke any of them (`DELETE /api/v1/security/api-keys/{id}`, audited as `API_KEY_REVOKED_BY_ADMIN`). An ordinary user can neither list nor revoke other people's keys.
Tests	`tsc` clean, 156 unit, 234 integration (7 new, with real sign-ins), 35 security.

Choices made, to confirm.

1. The 15-minute idle timeout is the proposal of decision 13, not an official policy.
2. "Sensitive account" is read as: sensitive permission in the role, or any clearance above standard.
3. 90 days is both the longest validity and the rotation period.

Limits.

1. The sensitive flag of a session is set when it is created; a role that gains a sensitive permission later does not change the sessions already open (a change of role or clearance ends them).
2. A key inserted directly in the database without the restriction flag keeps the legacy behaviour; the automated tests use such keys. The application never creates one, and anyone able to insert it already controls the database.
3. There is no automatic rotation or reminder: a key simply stops working after 90 days and its owner creates a new one.
4. Not browsed in the interface.

14. Summary of the seven lots

Lot	Subject	Commit
1	Technical and security administration separated from police command	cfa6070
2	Provincial title and central directions from decree 0572/2023	d1ec0ad
3	Clearance tiers and MFA by sensitivity	80adab9
4	Approval workflow for accounts, roles and clearances	dcf3e7c
5	Effects of a reassignment on access	de5f601
6	Tamper-evident audit log and audited reads	4eedbbe
7	Sessions of sensitive accounts and API keys	see the git log

Still open, and needing the Direction or a later decision.

1. The ministerial arrêté with the detailed organisation (sub-directions, services, commissariats) and the official clearance levels.
2. Whether police command should approve the technical and security administrators; whether the departmental level exists.
3. The audit retention period and where to record the head of the audit chain outside the database.
4. The 15-minute timeout, the 7-day expiry of an approval and the 48-hour custody limit.
5. Not yet built: the real `OWN` scope, a retry of an approved change stopped between its vote and its execution, a list screen of work to reassign, reading of confidential documents (the documents module itself).
6. None of the new screens has been browsed in the interface, and no external security audit has been carried out.

TECHNOTCHAD